

Information Security Risk Register

FinFlow Ltd — ISO/IEC 27001:2022 Readiness Engagement

Sample Consulting Deliverable | Likelihood & Impact scored 1 (Low) – 5 (High); Rating = Likelihood x Impact

ID	Risk Description	Category	Likelihood	Impact	Rating	Treatment & Mitigation
R-01	Unauthorized access to customer payment data via compromised employee credentials	Access Control	3	5	15	Mitigate - enforce MFA on all systems, quarterly access reviews
R-02	Insecure API endpoints exposing customer financial data to external actors	Application Security	3	5	15	Mitigate - API security testing in CI/CD, rate limiting, WAF rules
R-03	Data breach via third-party vendor (e.g. payment processor, email provider)	Third-Party Risk	2	5	10	Mitigate - formal vendor risk assessments and DPAs for all critical suppliers
R-04	Ransomware attack on production infrastructure disrupting service availability	Availability	2	5	10	Mitigate - endpoint protection, offline backups, tested recovery procedures
R-05	Loss of encryption keys or misconfigured KMS leading to data exposure	Cryptography	2	4	8	Mitigate - key rotation policy, least-privilege KMS access, audit logging
R-06	Insider threat - employee misuses privileged access to export customer data	Insider Threat	2	4	8	Mitigate - privileged access monitoring, DLP controls, segregation of duties
R-07	Phishing attack leading to compromised credentials or malware installation	Social Engineering	4	3	12	Mitigate - security awareness training, email filtering, MFA
R-08	Non-compliance with GDPR resulting in regulatory fines or customer loss	Regulatory/Legal	2	4	8	Mitigate - DPO oversight, data mapping, privacy impact assessments
R-09	Unpatched vulnerability in production systems exploited before remediation	Vulnerability Mgmt	3	4	12	Mitigate - formal patch SLA, quarterly vulnerability scanning
R-10	Business continuity failure during AWS regional outage	Availability	2	3	6	Mitigate - multi-AZ architecture, documented and tested DR plan
R-11	Inadequate offboarding leaves former employee with residual system access	Access Control	2	3	6	Mitigate - automated offboarding checklist, 24-hour access revocation SLA

ID	Risk Description	Category	Likelihood	Impact	Rating	Treatment & Mitigation
R-12	Shadow IT - staff using unapproved SaaS tools to handle customer data	Governance	3	2	6	Accept with monitoring - approved SaaS list, periodic audits

Risk Rating Key

High (15-25): Immediate mitigation required | Medium (8-14): Mitigation planned within quarter | Low (1-7): Monitor / accept

Summary

12 risks were identified across access control, application security, third-party, availability and regulatory categories. 3 risks are rated High and require immediate attention: unauthorized access to payment data (R-01), insecure API endpoints (R-02), and third-party vendor data breach (R-03). All identified risks have a documented treatment plan; 11 of 12 are recommended for active mitigation, with 1 lower-rated risk (R-12, Shadow IT) accepted with ongoing monitoring given its comparatively low impact.